

ENTERPRISE BUSINESS REQUIREMENTS DOCUMENTATION

AI-Powered Healthcare Medical Institution Platform

Business Requirements Document

Volume II of IV | Security, Privacy, Data Governance & Responsible AI Architecture

Document Title	AI-Powered Healthcare Medical Institution Platform — Business Requirements Document
Volume	Volume II of IV — Security, Privacy, Data Governance & Responsible AI Architecture
Document Version	1.0
Document Status	Draft for Executive Review
Classification	Confidential — Internal Use
Prepared For	Office of the Chief Information Officer / Chief Technology Officer
Prepared By	Enterprise Architecture & Digital Health Strategy
Date	September 2026
Total Pages	17

This document and its contents are confidential and proprietary. It is intended solely for authorized internal review and downstream architecture, design, and engineering planning, and does not itself constitute application source code or a certification of regulatory compliance.

Table of Contents

9. HIPAA and Healthcare Privacy..... 3

10. PII and PHI Protection.....4

11. Role-Based Access Control..... 5

12. Audit Logging.....6

13. Data Governance & Retention..... 8

14. Responsible AI..... 9

15. AI Safety.....11

16. AI Output Validation..... 11

17. Required Generative AI Features.....12

18. Customized LLM..... 14

19. AI Governance Matrix & Governance Framework.....15

Document Revision History

VERSION	DATE	AUTHOR	DESCRIPTION
1.0	September 2026	Enterprise Architecture & Digital Health Strategy	Initial draft issued for executive review.

9. HIPAA and Healthcare Privacy

Compliance notice: This section defines project-level design requirements informed by the structure of HIPAA. It is not a legal compliance determination, and the platform described here is not automatically HIPAA compliant by virtue of meeting these requirements. Formal HIPAA compliance requires legal review, a completed risk assessment, execution of Business Associate Agreements where applicable, and validation by qualified privacy/security/legal counsel and, where required, a compliance auditor. These requirements should be treated as engineering and governance inputs to that process, not a substitute for it.

9.1 Privacy Rule–Aligned Requirements

- Limit collection, use, and disclosure of PHI to the minimum necessary for the specific purpose of the request (minimum necessary standard).
- Provide role-scoped access so that each user category (Section 11) can view only the PHI relevant to their function.
- Support patient access to their own health information consistent with applicable patient-rights principles.
- Maintain a documented notice of information practices explaining how patient information is used, accessible from the platform.
- Restrict PHI use for AI training, analytics aggregation, or educational content generation to governed, approved workflows (see Sections 14–18).

9.2 Security Rule–Aligned Requirements

9.2.1 Administrative Safeguards

- Designated privacy and security responsibility roles (e.g., AI Governance Administrator, Compliance Personnel) as defined in the stakeholder matrix.
- Documented workforce access-authorization and termination procedures for provisioning/de-provisioning system access.
- Periodic access review and re-certification of role assignments and permissions.
- Documented security incident response procedure, including AI-related incidents (Section 14.11).
- Security awareness expectations for staff handling PHI, including AI-assisted workflows.

9.2.2 Technical Safeguards

- Unique user identification and secure authentication (including multi-factor authentication for administrative and clinical roles).
- Role-based access control enforced at the application and data layer (Section 11).
- Automatic session timeout and re-authentication for inactive sessions accessing PHI.
- Encryption of PHI in transit (e.g., TLS) and at rest (e.g., AES-256 or equivalent) throughout the environment, including AI processing pipelines.
- Comprehensive audit controls recording access to and modification of PHI (Section 12).
- Integrity controls to detect unauthorized alteration of PHI.

9.2.3 Physical Safeguard Considerations

- Hosting environment (data center / cloud infrastructure) must provide physical access controls, environmental safeguards, and facility security consistent with the sensitivity of PHI stored.
- Workstation and device-use policies for staff accessing PHI, including remote-access considerations.
- Media disposal and reuse procedures for any hardware that has stored PHI.

9.3 Breach Notification Considerations

- Documented process to detect, assess, and classify potential PHI security incidents, including a defined severity/risk classification.
- Defined internal escalation path from detection through Compliance Personnel and institutional leadership.
- Breach-assessment criteria (e.g., nature of PHI involved, unauthorized recipient, risk of re-identification) documented for use in the assessment process.
- Notification timelines and recipient categories (affected individuals, regulators, and other required parties) to be defined in coordination with legal counsel and applicable jurisdictional requirements — this document does not prescribe specific timelines.

9.4 Confidentiality, Integrity, and Availability

PRINCIPLE	REQUIREMENT	SUPPORTING CONTROLS
Confidentiality	PHI/PII accessible only to authorized, authenticated roles under minimum-necessary and need-to-know principles.	RBAC, encryption, session controls, audit logging.
Integrity	PHI/PII protected from unauthorized or accidental alteration or destruction.	Validation rules, referential integrity, checksums/versioning, change audit trail.
Availability	Authorized users can access PHI/PII when needed for care and operations.	Redundancy, backup/recovery (Section 13), monitoring, disaster recovery planning.

10. PII and PHI Protection

10.1 Requirements

- **Data Classification:** every data element in the platform's data model is assigned a classification level (Section 10.2) that determines applicable controls.
- **PII Identification:** fields such as name, contact details, government identifiers, and demographic data are explicitly tagged as PII within the data model.
- **PHI Identification:** diagnosis, medication, monitoring, severity, and clinical-history fields are explicitly tagged as PHI.
- **Data Minimization:** only data elements necessary for a defined function are collected, displayed, or passed into AI workflows.
- **Data Masking:** partial masking (e.g., truncated identifiers) applied in interfaces/logs where full values are not operationally required.
- **Encryption:** PII/PHI encrypted at rest and in transit using industry-standard algorithms and managed key infrastructure.
- **Secure Transmission:** all PII/PHI transmission (including to/from AI components) occurs over authenticated, encrypted channels.
- **Secure Storage:** PII/PHI stored in access-controlled, encrypted data stores separate from general application/marketing content.
- **Access Restrictions:** access enforced through RBAC (Section 11) with minimum-necessary scoping per request.
- **Data Redaction:** capability to redact PII/PHI from exports, reports, and AI inputs where full detail is not required.

- De-Identification: capability to strip direct identifiers from data used for aggregate analytics or model evaluation.
- Anonymization: for datasets intended for broad analytical or AI-evaluation use, apply anonymization techniques designed to prevent re-identification, subject to institutional policy review.

10.2 Data Classification Matrix

DATA CATEGORY	EXAMPLES	CLASSIFICATION	REQUIRED CONTROLS	AI USAGE CONSTRAINT
Direct Identifiers	Full name, date of birth, national/government ID, contact details.	PII — Restricted	Encrypted at rest/in transit; masked in logs; role-restricted display.	Excluded from AI prompts unless explicitly required and governed.
Clinical / Diagnostic Data	Diagnosis, treatment notes, severity indicators, clinical history.	PHI — Restricted	Encrypted; clinical-role access only; full audit trail on access.	Governed AI use only; never used to auto-generate diagnoses (Section 15).
Medication Data	Current/historical medication records.	PHI — Restricted	Encrypted; clinical-role access only; audit trail on access/change.	May inform AI-assisted educational content; not autonomous prescribing.
Monitoring / Severity Data	Real-time or near-real-time status and severity indicators.	PHI — Restricted	Encrypted; clinical-role access; time-bounded retention policy per Section 13.	May inform operational analytics; excluded from patient-facing AI without review.
Administrative / Account Data	User accounts, roles, permissions, credentials.	Confidential — Internal	Encrypted credentials; RBAC; MFA; audit trail on change.	Not used as AI training/context data.
Operational / Aggregate Metrics	De-identified counts, rates, and trend data.	Internal — Analytics	Access scoped to analytics/executive roles; de-identified by design.	Usable in AI-assisted reporting under governance review.
Public / Marketing Content	Institutional information, service descriptions.	Public	No special access restriction.	Freely usable as AI/RAG context (Section 18).

11. Role-Based Access Control

The RBAC framework applies least privilege, need-to-know, separation of duties, privileged access management, and role segregation. No single non-super-admin role combines unrestricted patient-data access with unrestricted administrative/security configuration access.

11.1 Guiding Principles

- Least Privilege: each role receives only the permissions required to perform its defined function.
- Need-to-Know: patient data access is further scoped to assigned patients/units where operationally applicable, not institution-wide by default.
- Separation of Duties: account/role creation, permission changes, and audit review are separated so no single non-super-admin role can grant itself elevated access undetected.
- Privileged Access Management: Super Administrator and Administrator actions require MFA, are time-bounded where feasible, and are fully audited.

- Role Segregation: clinical roles, administrative roles, analytics roles, and AI governance roles are kept structurally distinct.

11.2 RBAC Matrix

ROLE	PERMISSIONS	PATIENT DATA ACCESS	ADMINISTRATIVE ACCESS	AI ACCESS	REPORTING ACCESS
Super Administrator	Full system configuration; manages Administrators; emergency access override (logged).	Full (governed, logged, minimum-necessary applied)	Full	Full incl. governance config	Full
Administrator	Manage patients/administrative records; approve workflows; manage Co-Administrators.	Institution-wide, role-scoped	High (institution-level, non-security-config)	Request + review AI-assisted reports	Full (institution-level)
Co-Administrator	Delegated administrative tasks per scope defined by Administrator.	Scoped per delegation	Scoped (delegated)	Request AI-assisted reports (scoped)	Scoped
Physician	Diagnose, treat, review history, monitor severity, request AI education content for patients.	Assigned patients (clinical need-to-know)	None	Request patient-education AI content; view AI review status	Clinical reports (assigned patients)
Nurse	Monitor patients, administer/track medication, update status.	Assigned patients/unit	None	View AI education content status (no generation rights)	Unit-level operational reports
Clinical Staff	Support diagnostic/treatment workflows within defined scope.	Assigned patients (role-scoped)	None	View-only AI content relevant to assigned patients	Limited, role-scoped
Data Analyst	Build and review analytics/reports.	De-identified/aggregate only	None	Request AI-assisted report drafts (aggregate data)	Full analytics/reporting (aggregate)
AI Governance Administrator	Review/approve/reject AI outputs; configure AI governance policy and model boundaries.	None by default; case-by-case access for review with justification, logged	AI-governance configuration only	Full AI governance access (review, approve, reject, configure)	AI governance reporting
Authorized Healthcare User	Care-coordination access to relevant records within defined role boundary.	Role-scoped, need-to-know	None	View-only, role-scoped	Role-scoped

12. Audit Logging

Every audit record captures a consistent structure to support security review, compliance reporting, and forensic reconstruction of activity.

12.1 Audit Record Structure

FIELD	DEFINITION
Audit Event	The action category being logged (e.g., Record Viewed, Login Failed).
Actor	The authenticated user/role/system identity performing the action.
Timestamp	Date/time of the event, recorded in a consistent, synchronized time source.
Action	The specific operation performed (e.g., read, create, update, delete, approve, reject, export).
Object	The record/resource affected (e.g., patient ID reference, report ID, AI content ID) — referenced, not duplicated, in the log.
Result	Outcome of the action (success, failure, denied).
Source	Origin of the action (application interface, API, administrative console, system process).
Risk Level	Assigned severity/sensitivity classification of the event (e.g., Low, Medium, High, Critical).

12.2 Required Audit Events

AUDIT EVENT	ACTOR	TIMESTAMP	ACTION	OBJECT	RESULT	SOURCE	RISK LEVEL
Login	Authenticated user	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	High
Logout	Authenticated user	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Low
Failed Authentication	Attempted user identity	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Medium–High (escalates with repetition)
Patient Record Viewed	Clinical/ Admin user	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Medium
Patient Record Created	Clinical/ Admin user	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Medium
Patient Record Modified	Clinical/ Admin user	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	High
Patient Record Deleted	Administrator	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Critical
Administrative Change	Administrator/System Admin	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	High
RBAC / Role or Permission Change	System Administrator	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Critical
AI Content Generated	System (on behalf of)	System-generated	Per event definition	Referenced record/resource	Success / Failure /	App / API / Admin	Medium

AUDIT EVENT	ACTOR	TIMESTAMP	ACTION	OBJECT	RESULT	SOURCE	RISK LEVEL
	requesting user)	(UTC)		e ID	Denied	Console	
AI Content Approved / Rejected	AI Governance Administrator	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	High
Report Generated / Viewed	Admin/Analyst/Executive	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Medium
Data Export	Admin/Analyst	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	High
Security Event (e.g., logout, privilege escalation attempt)	System / Actor under review	System-generated (UTC)	Per event definition	Referenced record/resource ID	Success / Failure / Denied	App / API / Admin Console	Critical

12.3 Audit Logging Requirements

- Audit logs are immutable/tamper-evident and stored separately from primary application data.
- Audit logs are retained per the retention framework in Section 13 and are themselves subject to access control and audit.
- Audit log access is itself a logged, high-risk event restricted to Compliance Personnel and authorized System Administrators.
- Audit logging covers AI-specific events distinctly from standard record events, to support Responsible AI oversight (Section 14).

13. Data Governance & Retention

13.1 Governance Requirements

- **Data Ownership:** each data domain (patient, clinical, administrative, AI, analytics) has a designated institutional owner accountable for its accuracy and appropriate use.
- **Data Stewardship:** assigned stewards (e.g., Compliance Personnel, AI Governance Administrator) responsible for day-to-day policy adherence within their domain.
- **Data Classification:** all data classified per the matrix in Section 10.2, with classification driving access, retention, and handling rules.
- **Data Quality:** validation rules, completeness checks, and periodic quality review applied to patient and clinical data.
- **Data Lineage:** traceability of where data originated and how it has been transformed (particularly for analytics and AI-assisted outputs).
- **Data Lifecycle:** defined stages — creation, active use, archival, and disposal — documented for each data category.
- **Data Access:** governed by the RBAC framework (Section 11) and minimum-necessary principle.
- **Data Accountability:** every create/update/delete action attributable to an actor via the audit trail (Section 12).

- Metadata Management: classification, ownership, lineage, and retention metadata maintained alongside the data model itself.

13.2 Data Retention Framework

Retention periods are intentionally not prescribed as fixed numbers in this document. Actual retention periods must be configurable and determined in consultation with legal counsel, applicable healthcare regulations, institutional policy, contractual obligations, and jurisdictional requirements, which vary by location and record type.

DATA CATEGORY	RETENTION APPROACH	DISPOSAL / ARCHIVAL APPROACH
Patient Records (PHI)	Long-term retention typical for clinical records; exact period configurable per applicable law/policy.	Per governance policy, then secure archival or disposal.
Audit Logs	Retained for a duration sufficient to support security review and compliance audit; configurable.	Immutable archival, then policy-defined disposal.
AI-Generated Content & Review Records	Retained alongside the approval/rejection record for traceability; configurable.	Archived with linked governance decision record.
Reports (Operational/Administrative)	Retained per institutional reporting policy; configurable.	Archived or disposed per policy.
Analytics / Aggregate Data	Retained per analytics policy; may be retained longer if de-identified.	Archived; disposal per policy if re-identification risk exists.
Administrative Records	Retained per institutional administrative policy; configurable.	Archived or disposed per policy.
System Logs (non-audit)	Retained per operational/security policy; typically shorter than audit logs.	Rotated/disposed per policy.
Archives	Retained per institutional archival policy and applicable legal hold requirements.	Secure long-term storage with restricted access; disposal per policy.

13.3 Secure Disposal

- Disposal methods must render PHI/PII unrecoverable (e.g., cryptographic erasure of encrypted data, certified media destruction where applicable).
- Disposal actions are themselves logged as audit events, including actor, scope, and method.
- Data subject to legal hold is excluded from routine disposal until the hold is released.

14. Responsible AI

The following requirements establish the governance backbone for every AI capability in the platform (Sections 17–18). They apply uniformly regardless of which specific AI feature is invoked.

14.1 AI Transparency

All AI-generated content is visibly labeled as AI-generated/AI-assisted at the point of display, with a summary of what the AI did and did not do (e.g., "drafted," not "finalized").

14.2 AI Accountability

Every AI output has a traceable chain of responsibility: requesting user, model/version used, and the human reviewer who approved or rejected it.

14.3 Human Oversight

No AI output reaches a patient or informs a clinical/administrative decision without passing through the human review stage defined in Section 16.

14.4 Explainability

AI outputs relevant to clinical or administrative decisions are accompanied by a summary of the inputs/sources used (e.g., which record fields or knowledge-base sources informed the content), to the extent the underlying model supports it.

14.5 Bias Monitoring

Periodic review of AI outputs for demographic, linguistic, or condition-based disparities in quality or content, with findings logged and remediated.

14.6 Fairness

AI-assisted educational content and reporting are evaluated for equitable quality and accessibility across patient populations.

14.7 AI Safety

AI capabilities are scoped to non-autonomous, decision-support and educational functions only, per the boundary defined in Section 15.

14.8 Privacy & Security (AI-Specific)

AI processing pipelines inherit the same encryption, access-control, and minimum-necessary requirements as the rest of the platform (Sections 9–10); PHI exposure to AI components is governed and logged.

14.9 Model Monitoring

Ongoing monitoring of AI output quality, error rates, and drift, with defined escalation when performance falls outside acceptable bounds.

14.10 Model Performance Tracking

Defined quality metrics (e.g., reviewer rejection rate, correction rate) tracked over time per AI capability.

14.11 AI Incident Management

A documented process to log, investigate, and remediate AI-related incidents (e.g., inaccurate medical content, inappropriate output), integrated with the general security incident process (Section 9.2.1).

14.12 AI Documentation

Each AI capability documented with its purpose, scope, data inputs, model/version, known limitations, and governance owner.

14.13 AI Versioning

Model and prompt-configuration versions tracked, with the version used recorded against every AI output for traceability.

14.14 AI Risk Classification

Every AI capability assigned a risk level (Section 19) that determines the intensity of validation, review, and audit applied.

15. AI Safety

This section draws an explicit, non-negotiable boundary between AI Assistance and Clinical Decision Making. This boundary applies to every AI capability described in this document.

DIMENSION	AI ASSISTANCE (PERMITTED)	CLINICAL DECISION MAKING (HUMAN-ONLY)
Who decides	The AI system	A qualified human (physician/clinical staff, per role)
Scope of output	Drafts, illustrations, narration, summaries, educational explanations	Diagnoses, treatment decisions, medication orders, discharge/admission approvals
Patient-specific clinical conclusions	Never generated as authoritative by AI	Always determined by qualified clinical staff
Emergency / high-risk scenarios	AI may surface general educational information only, clearly labeled	All emergency and high-risk decisions remain fully human-led, unmodified by AI involvement
Required workflow step	AI output is a draft/candidate	Human review and approval (Section 16) required before any use

15.1 Explicit Safety Constraints

- The AI must never independently generate, finalize, or transmit a diagnosis, treatment plan, medication order, or discharge/admission decision.
- Patient-specific, diagnostic, medication-related, or emergency content generated with AI assistance is always routed to qualified human clinical review before any use (Section 16) — no exceptions.
- AI-generated educational content is scoped to general, non-patient-diagnostic information (e.g., "what is a kidney transplant") rather than an assessment of a specific patient's condition, unless explicitly reviewed and approved by a qualified clinician for that patient.
- In any ambiguous case where it is unclear whether content is educational or diagnostic in effect, the platform defaults to requiring clinical review.
- AI system prompts and configuration are governed (Section 18) so that the model is not positioned, worded, or presented to users as a diagnostic authority.

16. AI Output Validation

Every AI output — regardless of capability — passes through the same governed pipeline before it can be published or used. No stage may be skipped for patient-facing or clinical-support content.

16.1 Validation Workflow

STAGE	DESCRIPTION
1. AI Request	Authorized user submits a scoped request (e.g., educational content on a topic, report draft) through a governed interface; request is logged.

STAGE	DESCRIPTION
2. AI Generation	The Customized LLM / generative component produces a draft output using approved knowledge sources (Section 18); output is versioned and logged with model/version metadata.
3. Safety Validation (Automated)	Automated checks screen for disallowed content categories (e.g., attempted diagnostic statements, unsafe medical claims, PHI leakage) before the output proceeds.
4. Accuracy Review (Automated + Source Check)	Output is checked against source/knowledge-base references where feasible (Section 18.3) to flag unsupported or hallucinated claims.
5. Human Review	A qualified human reviewer (role depends on content type — clinical vs. administrative) evaluates the draft for correctness, tone, and appropriateness.
6. Administrative / Clinical Approval	Formal approve/reject/revise decision recorded by the AI Governance Administrator (administrative content) or qualified clinical staff (clinical/educational content touching patient care).
7. Publication / Use	Approved content is released to its intended audience with visible AI-generated labeling (Section 14.1).
8. Monitoring	Published content and its usage/feedback are monitored on an ongoing basis (Section 14.9–14.10); issues trigger the AI incident process (Section 14.11).

16.2 Rejection and Revision Handling

- Rejected content is retained (not deleted) with the reviewer's rationale, for audit and model-improvement purposes.
- Revision requests route back to Stage 2 (AI Generation) with reviewer feedback incorporated into the next draft; the revised draft re-enters the full pipeline — it does not skip validation stages.
- Version history for every AI output (all drafts, reviewer decisions, and the final approved version) is retained per Section 13.2.

16.3 Version Control & Audit Trail

- Each AI output instance is assigned a unique content ID linking it to its request, all draft versions, reviewer decisions, and final disposition.
- The audit trail (Section 12) captures AI Content Generated and AI Content Approved/Rejected as distinct, required event types.
- Approved content that is later superseded (e.g., updated educational material) retains its version history rather than being overwritten.

17. Required Generative AI Features

Each generative capability below is scoped as educational/decision-support only, subject to the full validation workflow in Section 16, and clearly labeled as AI-generated at the point of use.

17.1 Text-to-Image Generation — Healthcare Educational Images

- Purpose: produce non-diagnostic, illustrative images that support patient understanding of anatomy, procedures, or conditions.
- Constraint: generated images must never be presented as, or capable of being mistaken for, an actual patient's diagnostic scan or medical imaging evidence.
- Labeling: every generated image carries a persistent, clearly visible label such as "Synthetic Educational Illustration — Not an Actual Patient Scan" embedded in the display and image metadata.

- Governance: routed through the full validation workflow (Section 16) before patient-facing use; clinical reviewer confirms medical accuracy and appropriateness of the illustration.

17.2 Text-to-Audio Generation — Healthcare Educational Audio

- Purpose: convert approved educational text into audio to improve accessibility.
- Constraint: audio content is limited to already-reviewed/approved educational text; the audio generation step does not introduce new clinical claims.
- Labeling: audio content is introduced with a spoken and visible disclaimer identifying it as AI-generated educational material.

17.3 AI Narration — Narrated Healthcare Educational Material

- Purpose: provide a guided, spoken walkthrough of educational content (e.g., explaining a procedure step by step).
- Constraint: narration scripts are derived only from approved educational content that has already passed the validation workflow (Section 16); narration is not a new, unreviewed generation path.
- Accessibility: narration includes pacing and clarity appropriate for patients with varying health literacy, and supports accompanying visual/text captions.

17.4 AI-Generated Healthcare Educational Content

- Purpose: generate accessible written explanations of diagnoses, procedures, and medications for patient understanding.
- Constraint: content is general/educational in nature; any content that would function as a patient-specific diagnostic or treatment statement is escalated to clinical review as clinical content, not general education (Section 15.1).
- Validation: 100% of educational content passes through the full workflow in Section 16 before patient delivery.

17.5 Demonstration / Validation Test Scenarios

This document defines requirements and acceptance criteria only; it does not itself generate medical imagery, audio, or narration content. Actual generation occurs within the governed application pipeline described in Section 16, during formal User Acceptance Testing (UAT), with the outputs subject to the same safety validation, clinical review, and approval steps as any production content.

17.5.1 Demonstration Case: Synthetic Educational Scan-Style Image

- Scenario: as part of UAT for the text-to-image capability, the system must demonstrate generation of a clearly labeled, synthetic, scan-style illustrative image depicting a failed kidney transplant scenario, for educational use.
- Acceptance Criteria: the generated image is visually and textually labeled as synthetic/educational; it must never be presented, formatted, or metadata-tagged in a way that could be mistaken for an actual patient's diagnostic scan or used as diagnostic evidence.
- Governance: this demonstration case is treated as clinical-adjacent content and requires clinical reviewer sign-off (Section 16) confirming both medical-educational accuracy and unambiguous synthetic labeling before it is considered validated.
- Documentation: the demonstration output, reviewer decision, and approval record are retained per Section 13.2 as part of the AI capability's validation evidence.

17.5.2 Demonstration Case: Kidney Transplant Procedure Narration

- Scenario: as part of UAT for the AI narration capability, the system must demonstrate a 3–4 minute AI-generated educational narration explaining the kidney transplant procedure in general, non-patient-specific terms.
- Acceptance Criteria: narration content is sourced only from approved educational text (Section 17.3/17.4) that has already passed the Section 16 validation workflow; narration duration and pacing are appropriate for patient comprehension; an opening disclaimer identifies the content as AI-generated general education, not personalized medical advice.
- Governance: subject to the same clinical review and approval as the underlying educational text before being marked validated for production use.

18. Customized LLM

The Customized LLM is the governed generative engine behind the AI features in Section 17. It is designed as a constrained, retrieval-grounded assistant — not an open-ended general-purpose model — to reduce the risk of uncontrolled clinical claims.

18.1 Healthcare Knowledge Sources & Retrieval-Augmented Generation (RAG)

- The model is grounded via Retrieval-Augmented Generation against a curated, institutionally approved knowledge repository (clinical education references, institutional policies, approved procedure descriptions) rather than relying solely on parametric/general knowledge.
- Knowledge repository content is version-controlled, sourced from vetted references, and subject to periodic clinical review for currency and accuracy.
- Retrieval scope is restricted by capability: e.g., patient-education requests retrieve only from the educational knowledge base, not from raw patient records across the institution.

18.2 Prompt & Context Management

- System prompts explicitly constrain the model's role to educational/administrative drafting and explicitly instruct it not to present itself as a diagnostic authority.
- Context passed to the model is minimum-necessary and scoped per request (e.g., only the specific patient fields relevant to an approved educational request, not the full record).
- Prompt and context templates are version-controlled and subject to the same change-management/audit requirements as other governed configuration.

18.3 Model Governance, Evaluation & Hallucination Detection

- Model Governance: a designated AI Governance Administrator owns approval of model versions, prompt templates, and retrieval sources permitted for production use.
- Model Evaluation: new model versions or configuration changes undergo evaluation against a defined test set (including safety-boundary and accuracy test cases) before deployment.
- Hallucination Detection: automated cross-referencing of generated claims against retrieved source material (Section 18.1), with unsupported claims flagged for human reviewer attention during Stage 4 of the validation workflow (Section 16.1).
- Output Validation: all model outputs pass through the full Section 16 workflow; the Customized LLM has no direct, unreviewed path to patients or clinical records.

18.4 Human Oversight & Monitoring

- Human reviewers retain override authority at every stage; the model cannot self-approve or self-publish its own output.
- Ongoing monitoring tracks reviewer rejection/correction rates per model version as a leading indicator of quality drift.
- Version Management: every production model/prompt version is tagged, and every generated output records which version produced it, supporting rollback and traceability.

18.5 Security, Privacy & PHI Protection

- Model inference environment inherits platform-wide encryption, access control, and audit requirements (Sections 9–10).
- PHI passed into model context is minimum-necessary, logged, and excluded from any external logging/analytics used to improve the model unless explicitly de-identified and approved.
- The knowledge repository and RAG index are themselves classified and access-controlled per Section 10.2 to prevent unauthorized extraction of sensitive source material.

18.6 Integration Approach: Preventing Uncontrolled Clinical Decision-Making

The Customized LLM integrates with the platform as a request-scoped drafting service, not as a standing agent with autonomous access to patient records or workflow actions. It receives a bounded request and minimum-necessary context, generates a draft grounded in the approved knowledge repository, and returns that draft into the Section 16 validation pipeline. It has no direct write-access to patient records, no ability to independently trigger admission/discharge/medication actions, and no ability to publish content without passing through automated safety validation and human clinical/administrative approval. This architecture keeps every clinical decision with a qualified human while still allowing the model to accelerate drafting, education, and reporting work.

19. AI Governance Matrix & Governance Framework

19.1 AI Governance Matrix

AI CAPABILITY	RISK LEVEL	HUMAN OVERSIGHT	VALIDATION REQUIRED	APPROVAL REQUIRED	AUDIT REQUIRED
Patient Educational Content (Text)	Medium	Required (clinical reviewer)	Automated + human accuracy review	Clinical + AI Governance approval	Full
AI-Assisted Reporting (Admin/Operational)	Low–Medium	Required (administrative reviewer)	Automated + human review	AI Governance approval	Full
Text-to-Image (Educational Illustration)	Medium–High	Required (clinical reviewer)	Automated safety + clinical accuracy review	Clinical + AI Governance approval	Full
Text-to-Audio (Educational)	Low–Medium	Required (administrative reviewer)	Source-text validation (inherits underlying text approval)	AI Governance approval	Full
AI Narration (Educational)	Low–Medium	Required	Source-text validation	AI Governance	Full

AI CAPABILITY	RISK LEVEL	HUMAN OVERSIGHT	VALIDATION REQUIRED	APPROVAL REQUIRED	AUDIT REQUIRED
		(administrative reviewer)	(inherits underlying text approval)	approval	
Customized LLM — General Knowledge-Base Query (Staff-Facing)	Low	Recommended (spot-review)	Automated hallucination check	AI Governance approval (policy-level)	Full
Patient-Specific Diagnostic/Treatment Content	Prohibited for autonomous AI generation	Mandatory qualified clinician authorship	N/A — not an AI-autonomous capability	Clinical authority only; AI may not self-approve	Full

19.2 Enterprise Responsible AI Governance Framework — Summary

This framework consolidates Sections 14–19 into the governing principles for every AI capability in the platform:

- **Bounded Scope:** AI capabilities are limited to drafting, illustration, narration, and educational explanation — never autonomous clinical decision-making (Section 15).
- **Grounded Generation:** outputs are generated against a curated, version-controlled knowledge repository via RAG rather than open-ended generation (Section 18.1).
- **Mandatory Human-in-the-Loop:** every output passes automated safety/accuracy validation and qualified human review/approval before use; no publication path bypasses this (Section 16).
- **Full Traceability:** every output is versioned, attributable to a model/prompt version, and logged from request through approval and monitoring (Sections 12, 14.13, 18.4).
- **Transparent Labeling:** AI-generated content is always visibly and persistently identified as such to its audience (Section 14.1, 17.1–17.3).
- **Risk-Proportionate Controls:** the intensity of validation and approval scales with the AI Governance Matrix risk level (Section 19.1).
- **Continuous Oversight:** model performance, bias, and incident indicators are monitored on an ongoing basis, with a defined escalation and remediation path (Sections 14.9–14.11).
- **Data-Protective by Design:** AI processing inherits the platform's PII/PHI classification, minimum-necessary, and encryption requirements at every stage (Sections 9–10, 18.5).

Document Approval

This volume is submitted for executive review and sign-off by the stakeholders below prior to advancement into detailed design and engineering.

ROLE	NAME	SIGNATURE	DATE
Executive Sponsor			
Chief Information Officer			
Chief Technology Officer			
Chief Information Security Officer			

This concludes Volume II of the Business Requirements Document. Application source code is out of scope for this volume, and no claim of formal regulatory certification is made.